

Chapter One

Part - III

Attack types and Protection schema

Information Security
(SE7432)

Information Security

- ✎ Information security: protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, perusal, inspection, recording or destruction.
- ✎ Information security = confidentiality + integrity + availability + authentication.
- ✎ Information security is concerned with the confidentiality, integrity and availability of data regardless of the form the data may take: electronic, print, or other forms.
- ✎ Information security offers many areas for specialization including: securing network(s) and allied infrastructure, securing applications and databases, security testing, information systems auditing, business continuity planning and digital forensics science, etc.
- ✎ Security Trinity: the foundation for all security policies and measures that an organization develops and deploys.
 - ✎ The three legs of the "security trinity," prevention, detection, and response, comprise the basis for network security.

Information Security (Cont.)



1. Prevention:-

✎ is the foundation of the security trinity.

✎ To provide some level of security, it is necessary to implement measures to prevent the exploitation of vulnerabilities.

✎ In developing network security schemes, organizations should emphasize preventative measures over detection and response.

✎ It is easier, more efficient, and much more cost-effective to prevent a security breach than to detect or respond to one.

Information Security (Cont.)

2. Detection:-

- ✎ Once preventative measures are implemented, procedures need to be put in place to detect potential problems or security breaches, in the event preventative measures fail.
- ✎ The sooner a problem is detected the easier it is to correct and cleanup.

3. Response:-

- ✎ Organizations need to develop a plan that identifies the appropriate response to a security breach.
- ✎ The plan should be in writing and should identify who is responsible for what actions and the varying responses and levels of escalation.

Security Threats, Attacks and Vulnerabilities

- ✎ The objective of security is to protect valuable or sensitive organizational information while making it readily available.
- ✎ The threat comes from others who would like to acquire the information or limit business opportunities by interfering with normal business processes.
- ✎ Attackers trying to harm a system or disrupt normal business operations exploit vulnerabilities by using various techniques, methods, and tools.
- ✎ Attackers generally have motives or goals—for example, to disrupt normal business operations or steal information.
- ✎ To achieve these motives or goals, they use various methods, tools, and techniques to exploit vulnerabilities in a computer system or security policy and controls.

Goal + Method + Vulnerabilities = Attack

- ✎ What type of methods that attacker will use?

Security Threats, Attacks and Vulnerabilities (Cont.)

Actions the attackers will do:

Deleting and Altering Information:

 To prove a point – outside attacker

 To take revenge for something that happened to them – Inside Attacker

Committing information theft and Fraud

 By automating traditional methods (Financial Systems, School Grading Systems)

Disrupting Normal Business process

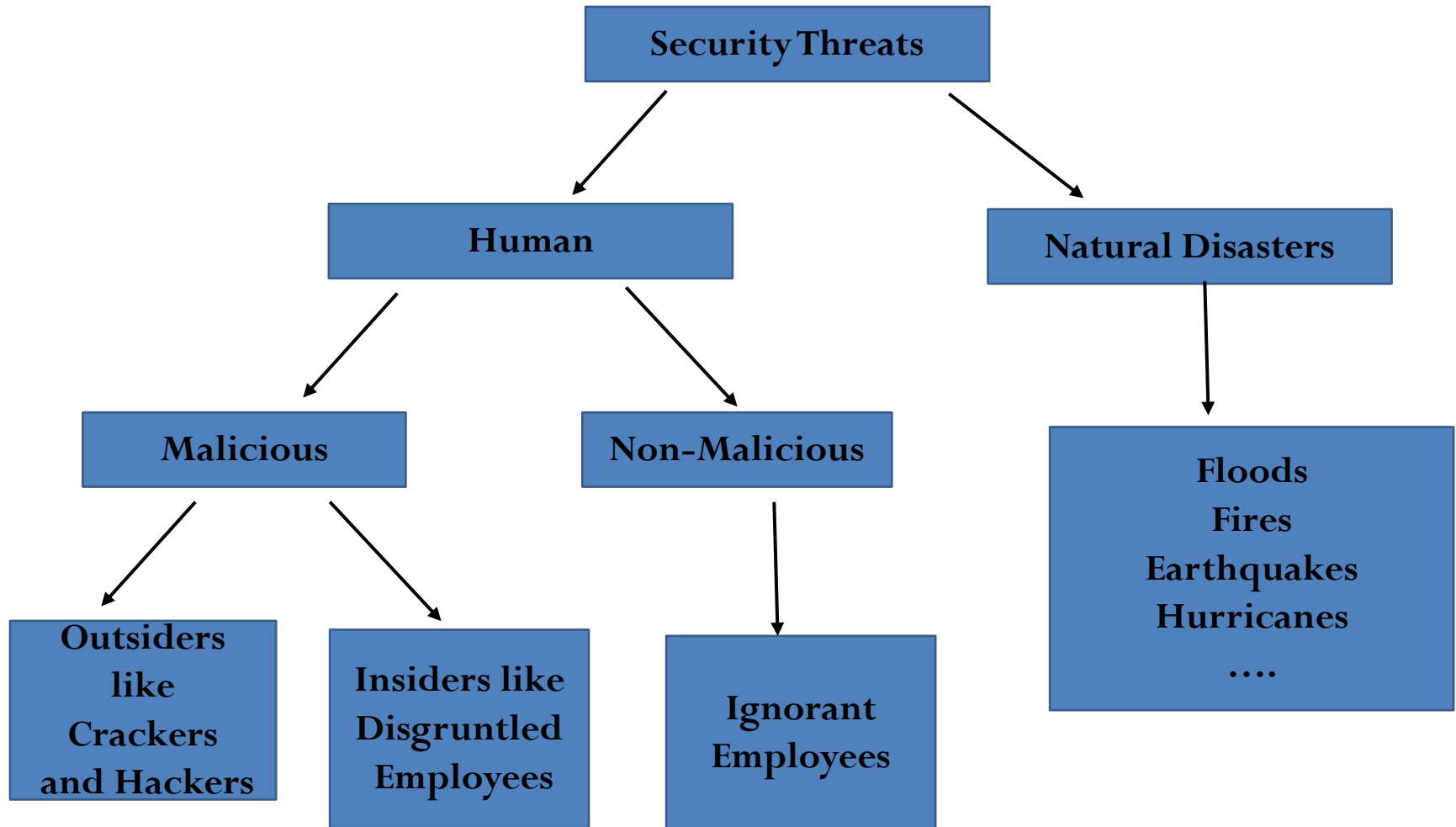
 To achieve its specific goal

 By using various methods (DoS attack)

Security Threats:

 A possible danger that might exploit a vulnerability to breach security and thus cause possible harm.

Security Threats



Security Threats, Attacks and Vulnerabilities (Cont.),

1. **Natural Disaster:-** Nobody can stop nature from taking its course.

- ✚ Earthquakes, hurricanes, floods, lightning, and fire can cause severe damage to computer systems.
- ✚ Information can be lost, downtime or loss of productivity can occur, and damage to hardware can disrupt other essential services.
- ✚ Few safeguards can be implemented against natural disasters, to have **disaster recovery plans and contingency plans** in place.
- ✚ Other threats such as **riots, wars, and terrorist attacks** could be included here.
- ✚ Although they are human-caused threats, they are classified as disastrous.

2. **Human Threats:-** *Malicious* threats consist of inside attacks by disgruntled or malicious employees and outside attacks by non-employees just looking to harm and disrupt an organization.

- ✚ **Insiders** are the most dangerous attackers, because they know many of the codes and security measures that are already in place.

Security Threats, Attacks and Vulnerabilities (Cont.),

- ✧ Insiders can affect availability by overloading the system's processing or storage capacity, or by causing the system to crash.
- ✧ Disgruntled employees can create both **mischief** and **sabotage** on a computer system.
- ✧ Common Examples of Computer-related Employee Sabotage include:
 - ✧ Changing/Deleting Data
 - ✧ Destroying data or programs with logic bombs
 - ✧ Crashing systems
 - ✧ Holding data hostage
 - ✧ Destroying hardware or facilities
 - ✧ Entering data incorrectly.
- ✧ **Hackers:**
 - ✧ People who either break in to systems for which they have no authorization
 - ✧ Intentionally overstep their bounds on systems for which they don't have legitimate access.
 - ✧ A programmer who constantly seeks further knowledge, freely share what they have discovered, and never intentionally damage data.

Security Threats, Attacks and Vulnerabilities (Cont.),

Crackers:

-  People who breaks into or otherwise violates system integrity with malicious intent.
-  They destroy vital data or cause problems for their targets.
-  Common methods for gaining access to a system include password cracking, exploiting known security weaknesses, network spoofing, and social engineering.
-  Malicious attackers normally will have a specific goal, objective, or motive for an attack on a system.

Ways to gain Access for deny Services

- | | | |
|---|---|---|
|  Viruses |  DoS Attacks (Will be discussed) |  Ping Storm |
|  Trojan Horses |  Email Hacking (Will be discussed) |  Snuffing |
|  Worms |  Intrusion Attack |  Packet Modification |
|  Password Cracking |  Social Engineering |  Smurfing Attack |

Security Threats, Attacks and Vulnerabilities (Cont.)

Denial of Services attacks:-

-  This attack exploits the need to have a service available.
-  A growing trend on the Internet because Web sites in general are open doors ready for abuse.
-  People can easily flood the Web server with communication in order to keep it busy.
-  Therefore, companies connected to the Internet should prepare for (DoS) attacks.
-  They also are difficult to trace and allow other types of attacks to be subdued.
-  DoS attacks are designed to prevent legitimate use of a service.
-  Attackers achieve this by **flooding** a network with more traffic than it can handle.
-  Examples of this include:
 -  Saturating network resources, thereby preventing users from using network resources.
 -  Disrupting connections between two computers, preventing communications between services.

Security Threats, Attacks and Vulnerabilities (Cont.),

- ✚ Preventing a particular individual from accessing a service.
- ✚ Disrupting services to a specific system or client.
- ✚ DoS attacks flood a remote network with an enormous amount of protocol packets.
- ✚ Routers and servers eventually become overloaded by attempting to route or handle each packet, within minutes, network activity exponentially rises and the network stops responding to normal traffic and service requests from clients.
- ✚ This is also known as a network saturation attack or bandwidth consumption attack.
- ✚ Attackers strike with various tools, including Trin00 and Tribe Flood Network (TFN, TFN2K).

[Read more on this tools]

✚ **Types of Denial of Service**

- ✚ Consuming Server Resources
- ✚ Saturating Network Resources
- ✚ Mail Bombing

Security Threats, Attacks and Vulnerabilities (Cont.),

Consuming Server Resources:-

-  Preventing the hosts or networks from communicating on the network
-  In most cases the victim of such an attack will have difficulty accepting any new, legitimate incoming connections.
-  This type of attack does not really affect any of the current connections or outgoing connections, normally it consumes an enormous amount of memory and processing power on the server, causing it to crash.
-  The location of the attacking system is difficult to trace because the attacker's system address was masquerading as a legitimate IP address.
-  The SYN flood attack
-  Use input source filtering to solve such problems

Security Threats, Attacks and Vulnerabilities (Cont.),

Saturating Network Resources:-

-  An intruder may also be able to consume all the available bandwidth on a network by generating a large number of packets directed to the network.
-  Typically, these packets are Internet Control Message Protocol (ICMP) echo packets, but in principle they may be anything.
-  Such attacks can be generated from a single computer or from several computers on different networks.
-  This is known as a distributed denial-of-service attack (DDoS).
-  The ICMP is used to convey status and error information including notification of network congestion and other network-related problems.
-  ICMP can be used to determine if a computer on the Internet is responding
-  Attackers don't use their own IP source address while creating the attack

Security Threats, Attacks and Vulnerabilities (Cont.),

✚ Three parties are involved Saturating resource attack, namely:

✚ The attacker

✚ The intermediary, can also be a victim

✚ The Victim

✚ Attackers use a variety of tools for this purpose:

✚ The tools enable the hackers to send ICMP echo request packets to multiple intermediary computers, causing all of them to respond to the same victim's source IP address.

✚ These tools could also be used to scan for network routers that do not filter broadcast traffic.

✚ These attacks typically exhaust bandwidth, router processing capacity, or network stack resources, breaking network connectivity to the victims

Security Threats, Attacks and Vulnerabilities (Cont.),

Mail Bombing:-

 is an e-mail based attack which sends floods of e-mail to a system until it fails.

 A system will fail in different ways, depending on the type of server and how it is configured.

 Here are typical failure modes:

 The e-mail server accepts e-mail messages until the disk where e-mail is stored fills up.

 The incoming queue is filled with messages to be forwarded until the queue reaches its limit.

 A particular user's server disk quota can be exceeded. This prevents subsequent mail from being received and may keep the user from getting work done.

Security Threats, Attacks and Vulnerabilities (Cont.),

Email Hacking

-  The most common mail transfer protocols (SMTP, POP3, IMAP4) do not typically include provisions for reliable authentication as part of the core protocol, allowing e-mail messages to be easily forged.
-  Nor do these protocols require the use of encryption that could ensure the privacy or confidentiality of e-mail messages.
-  Threats associated with e-mail
 -  Impersonation
 -  Eavesdropping
 -  Packet Reply
 -  Network Spoofing

Security Threats, Attacks and Vulnerabilities (Cont.),

3. ***Non-Malicious Threats:-*** The primary threat to data integrity comes from **authorized users** who are not aware of the actions they are performing.

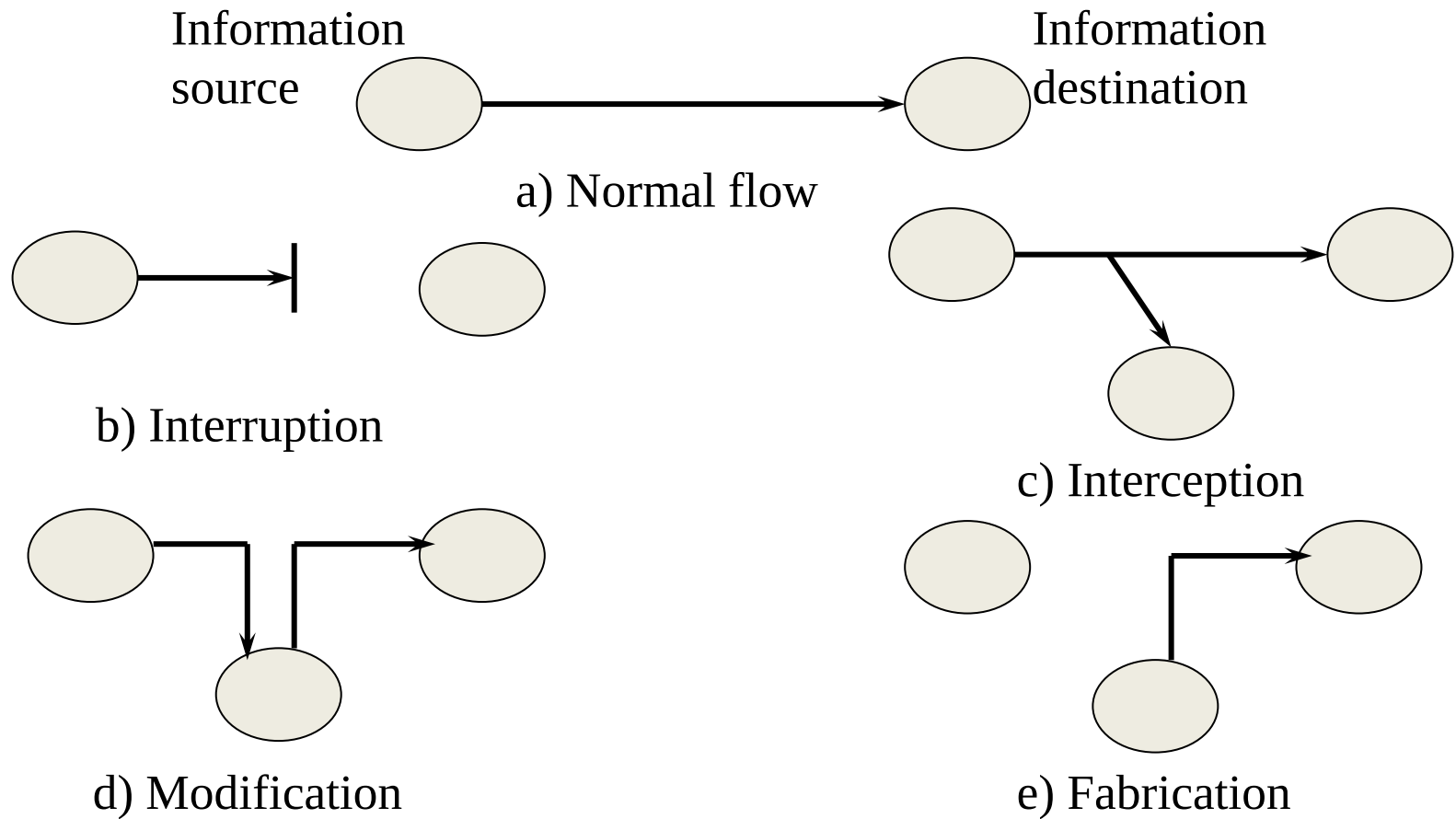
- ✎ Errors and omissions can cause valuable data to be lost, damaged, or altered.
- ✎ Usually come from employees who are untrained in computers and are unaware of security threats and vulnerabilities.
- ✎ Note that ignorant employees usually have no motives and goals for causing damage. The damage is accidental.
- ✎ Malicious attackers can deceive ignorant employees by using "social engineering" to gain entry.
- ✎ The attacker could masquerade as an administrator and ask for passwords and user names
- ✎ Users, data entry clerks, system operators, and programmers frequently make unintentional errors that contribute to security problems, directly or/and indirectly.
- ✎ Error can be a threat, such as a data entry error or a programming error that crashes a system.

Security Attack, Services and Mechanisms

- ✚ **Security attack:** any action that will compromise the security of information.
 - ✚ Is an assault on system security- an intelligent act that is a deliberate attempt to evade security services and violate the security policy of a system.
 - ✚ To obtain sensitive information
 - ✚ To destroy resources
 - ✚ To deny legitimate users access to resources.
- ✚ **Security mechanism:-** is a mechanism that is designed to detect , prevent, or recover from a security attack.
- ✚ **Security services:** A service that enhances the security of data processing systems and information transfers.
 - ✚ A security service makes use of one or more security mechanisms.

Security Threats, Attacks and Vulnerabilities (Cont.),

Security Attacks:



Security Threats, Attacks and Vulnerabilities (Cont.),

Attack Types

1. **Passive attacks:-** the type of attacks which do not change or modify the information flowing between the parties.

 Hard to detect – does not involve the other party or alter the data

 To obtain information

 Attempt to learn or make use of information from the system

 Don't affect the system resources

 Can be prevented rather than detected

 Example: Eavesdropping / monitoring of traffic

 Release of message content

 Traffic Analysis

Security Threats, Attacks and Vulnerabilities (Cont.),

2. **Active attacks:-** types of attacks which attempt to alter system resources or affect their operation

✎ Easier to detect – information stream is altered & involves the other party

✎ Hard to prevent - no absolute protection

✎ Modification of data stream

✎ Creation of false stream

✎ Examples: Masquerading

✎ Reply

✎ Modification of Message

✎ Denial of Service

Security Threats, Attacks and Vulnerabilities (Cont.),

Security Mechanisms:

 A collection of tools and techniques designed prevent and detect security attack/threat, and recover from a security attack

 Examples:

 Encipherment

 Digital Signature

 Access Control

 Data Integrity

 Authentication Exchange

 Traffic Padding

 Routing Control

 Notarization

Security Threats, Attacks and Vulnerabilities (Cont.),

Security Services

-  The collection of mechanisms, procedures and other controls that are implemented to help reduce the risk associated with threat.
-  For example, the identification and authentication service helps reduce the risk of the unauthorized user threat.
-  Some services provide protection from threats, while other services provide for detection of the threat occurrence. (logging or monitoring service)

Examples:

 Confidentiality/Privacy

 Authentication

 Integrity

 Audit

 Access control

 Availability

 Non-repudation

Review Exercise

Read more about the following contents

-  Typical security threats
-  Some network problems as a security threat
-  Identify network infrastructure security problems (Switches, routers, ...)
-  Pervasive Security Mechanisms